

Risk Assessment Policy

Langate Group

Purpose

The purpose of this policy is to define the methodology for the assessment and treatment of information security risks within Langate Group, and to define the acceptable level of risk as set by Langate Group's leadership.

Scope

Risk assessment and risk treatment are applied to the entire scope of Langate Group's information security program and to all assets which are used within Langate Group or which could have an impact on information security within it. This policy applies to all employees and contractors of Langate Group who take part in risk assessment and risk treatment.

Background

A key element of Langate Group's information security program is a holistic and systematic approach to risk management. This policy defines the requirements and processes for Langate Group to identify information security risks. The process consists of four parts: identification of Langate Group's assets, as well as the threats and vulnerabilities that apply; assessment of the likelihood and consequence (risk) of the threats and vulnerabilities being realized, identification of treatment for each unacceptable risk, and evaluation of the residual risk after treatment.

Policy

Risk Assessment

- The risk assessment process includes the identification of threats and vulnerabilities having to do with company assets.
- The first step in the risk assessment is to identify all assets within the scope of the information security program; in other words, all assets which may affect the confidentiality, integrity, and/or availability of information in the organization. Assets may include documents in paper or electronic form, applications, databases, information technology equipment, infrastructure, and external/outsourced services and processes. For each asset, an owner must be identified.
- The next step is to identify all threats and vulnerabilities associated with each asset. Threats and vulnerabilities must be listed in a risk assessment table. Each asset may be associated with multiple threats, and each threat may be associated with multiple vulnerabilities.
- An owner must be identified for each risk. The risk owner and the asset owner may be the same individual.
- Once risk owners are identified, they must assess:
 - Impact for each combination of threats and vulnerabilities for an individual asset if such a risk materializes.
 - Likelihood of occurrence of such a risk (i.e., the probability that a threat will exploit the vulnerability of the respective asset).
 - The criteria for determining impact and likelihood are defined in the tables below.
- The risk level is calculated by multiplying the impact score and the likelihood score.

Description of Impact Levels and Criteria:

Impact Value	Examples of risk factors
Incidental (1.0)	• Minimal loss/damage • Not reported to/by local media • Not reportable to regulator • Does not affect company customers • Isolated staff dissatisfaction
Minor (2.0)	• Minor financial loss • Minor localized reputational damage • Minor impact without increase in customer turnover • Reportable incident to regulator, no follow up • General staff morale problems and increase in turnover
Moderate (3.0)	• Moderate financial loss • National short-term negative media coverage • Increased customer turnover • Report of breach to regulator with immediate correction to be implemented • Widespread staff morale problems and high turnover
Major (4.0)	• Significant financial loss • National long-term negative media coverage; significant loss of market share • Report to regulator requiring major project for corrective action • Some senior managers leave, high turnover of experienced staff, not perceived as employer of choice
Extreme (5.0)	• Massive financial loss • International long-term negative media coverage; game-changing loss of market share • Significant prosecution and fines, litigation including class actions, incarceration of leadership • Multiple senior leaders leave

Description of Likelihood Value and Criteria:

Likelihood Value	Description
Rare (1.0)	Once in 100+ years (<10% chance of occurrence over the life of the company)
Unlikely (2.0)	Once in 50 to 100 years (10% to 35% chance of occurrence over the life of the company)
Possible (3.0)	Once in 25 to 50 years (35% to 65% chance of occurrence over the life of the company)
Likely (4.0)	Once in 2 to 25 years (65% to 90% chance of occurrence over the life of the company)
Almost Certain (5.0)	Up to once in 2 years (90% or greater chance of occurrence over the life of the company)

Risk Rating Criteria:

Risk Value	Risk Score
Low	Less than or equal to 4.0
Medium	Greater than 4.0 but less than or equal to 9.0

Risk Value	Risk Score
High	Greater than 9.0 but less than or equal to 16.0
Critical	Greater than 16.0

Risk Score Matrix:

Risk Score Matrix						
		IMPACT				
		INCIDENTAL (1.0)	MINOR (2.0)	MODERATE (3.0)	MAJOR (4.0)	EXTREME (5.0)
LIKELIHOOD	CERTAIN (5.0)	MEDIUM $5.0 \times 1.0 = 5.0$	HIGH $5.0 \times 2.0 = 10.0$	HIGH $5.0 \times 3.0 = 15.0$	CRITICAL $5.0 \times 4.0 = 20.0$	CRITICAL $5.0 \times 5.0 = 25.0$
	LIKELY (4.0)	LOW $4.0 \times 1.0 = 4.0$	MEDIUM $4.0 \times 2.0 = 8.0$	HIGH $4.0 \times 3.0 = 12.0$	HIGH $4.0 \times 4.0 = 16.0$	CRITICAL $4.0 \times 5.0 = 20.0$
	POSSIBLE (3.0)	LOW $3.0 \times 1.0 = 3.0$	MEDIUM $3.0 \times 2.0 = 6.0$	MEDIUM $3.0 \times 3.0 = 9.0$	HIGH $3.0 \times 4.0 = 12.0$	HIGH $3.0 \times 5.0 = 15.0$
	UNLIKELY (2.0)	LOW $2.0 \times 1.0 = 2.0$	LOW $2.0 \times 2.0 = 4.0$	MEDIUM $2.0 \times 3.0 = 6.0$	MEDIUM $2.0 \times 4.0 = 8.0$	HIGH $2.0 \times 5.0 = 10.0$
	RARE (1.0)	LOW $1.0 \times 1.0 = 1.0$	LOW $1.0 \times 2.0 = 2.0$	LOW $1.0 \times 3.0 = 3.0$	LOW $1.0 \times 4.0 = 4.0$	MEDIUM $1.0 \times 5.0 = 5.0$

Risk Remediation and Treatment

- As part of this risk remediation process, the Company shall determine objectives for mitigating or treating risks. All high and critical risks must be treated. For continuous improvement purposes, company managers may also treat medium and/or low risks for company assets.
- Treatment options for risks include the following options:
 - Selection or development of security control(s).
 - Transferring the risks to a third party, for example, by purchasing an insurance policy or signing a contract with suppliers or partners.
 - Avoiding the risk by discontinuing the business activity that causes such risk.
 - Accepting the risk: This option is permitted only if selecting other risk treatment options would cost more than the potential impact of the risk being realized.
- After selecting a treatment option, the risk owner should estimate the new impact and likelihood values after implementing the planned controls.

Regular Reviews of Risk Assessment and Risk Treatment

The Risk Assessment Report must be updated when newly identified risks are identified. At a minimum, this update and review shall be conducted **once per year**.

Unscheduled Risk Reassessments and Continuous Integration

- **Reassessment Triggers:** In addition to annual reviews, unscheduled information security risk reassessments must be triggered by:
 - The confirmation of a Medium, High, or Critical security incident.
 - Significant structural changes to the IT environment, including the adoption of new third-party services or major infrastructure overhauls.
 - The identification of a critical, unmitigated vulnerability or an immediate, severe shift in the threat intelligence landscape.
- **Process Integration:** Risk owners must integrate operational outputs into the risk assessment process. This includes reviewing threat intelligence reports, vulnerability scan results, and incident management data (such as frequent alerts identified by the Security Operations Center (SOC) or trends detected by the Identity Protection tool).
- **Evaluating Existing Controls:** During the risk assessment, before determining the residual risk score, the risk owner must formally evaluate the effectiveness of any existing information security controls. This includes assessing the current efficacy of automated controls, such as Conditional Access policies and implemented Data Loss Prevention (DLP) rules.

Reporting

The results of risk assessments and all subsequent reviews shall be documented in a Risk Assessment Report.

Policy version history

 Policy details

Policy name	Renewal date
Risk Assessment Policy	April 7, 2027
Description	
The Risk Assessment Policy defines the methodology for the assessment and treatment of information security risks within the company, and to define the acceptable level of risk as set by the company's leadership.	

 Version history

Version 1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
June 6, 2024	April 10, 2025	April 10, 2025	Eugene Skubach	Eugene Skubach	Eugene Skubach
Version 1.1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
April 14, 2025	No approval required	April 14, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.2					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 6, 2025	No approval required	May 6, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.3					
Explanation of changes					
'Revision History' section has been removed					

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
September 26, 2025	No approval required	September 26, 2025	Eugene Skubach	-	Eugene Skubach

Version 2

Explanation of changes

Updated section: Unscheduled Risk Reassessments and Continuous Integration

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
April 7, 2026	No approval required	-	Eugene Skubach	Eugene Skubach	-
